CENTRO ESTADUAL DE EDUCAÇÃO TECNOLÓGICA PAULA SOUZA

FACULDADE DE TECNOLOGIA DE LINS — PROF. ANTONIO SEABRA

CURSO SUPERIOR DE TECNOLOGIA EM ANÁLISE E DESENVOLVIMENTO DE SISTEMAS

MARCELO CARDOSO VENDRAME

GUSTAVO WILLIAN GODOY DA SILVA

MATHEUS SOARES GOMES

RICHARD DE OLIVEIRA BARRA JÚNIO

ESTRUTURA E ORGANIZAÇÃO DE TRABALHO ACADÊMICO PARA ADEQUAÇÃO DE SOFTWARE PARA ACADEMIAS SEGUNDO A LGPD

LINS/SP

2º SEMESTRE/2026

1. INTRODUÇÃO

O mercado fitness utiliza cada vez mais recursos digitais para organizar matrículas, controlar acessos, administrar pagamentos, elaborar fichas de treino e acompanhar avaliações físicas. Um software de gestão pode tornar essas atividades mais rápidas e organizadas, mas também concentra informações que exigem cuidado, como dados de identificação, contato, cobrança e informações relacionadas à saúde dos alunos.

No Brasil, a Lei nº 13.709/2018, conhecida como Lei Geral de Proteção de Dados Pessoais (LGPD), estabelece regras para o tratamento de dados pessoais e busca proteger a liberdade, a privacidade e o livre desenvolvimento da personalidade. A lei se aplica ao tratamento realizado em meios digitais e exige medidas de segurança e transparência compatíveis com os riscos envolvidos.

O problema de pesquisa deste trabalho é: como um software de gestão de academias deve ser estruturado e adaptado tecnicamente para contribuir com a conformidade às exigências da LGPD?

O objetivo geral é analisar e propor requisitos técnicos, jurídicos e operacionais para a adequação de um sistema de gerenciamento de academias à LGPD. Como objetivos específicos, pretende-se identificar os grupos de dados tratados, relacionar os princípios legais às funções do sistema e propor controles de acesso, mecanismos para atendimento dos direitos dos titulares e medidas de segurança da informação.

A justificativa está relacionada à variedade e à sensibilidade das informações utilizadas no setor. Avaliações físicas, restrições médicas e informações sobre saúde podem ser dados pessoais sensíveis. A biometria, quando vinculada a uma pessoa, também é dado pessoal sensível. Uma falha pode expor os alunos a riscos de privacidade e prejudicar a confiança na academia. Por isso, a proteção deve ser considerada desde o planejamento do software.

2. REFERENCIAL TEÓRICO

2.1 A Lei Geral de Proteção de Dados (LGPD)

A LGPD define dado pessoal como informação relacionada a pessoa natural identificada ou identificável. Exemplos no contexto de uma academia são nome, telefone, endereço, e-mail e número de identificação. Dado pessoal sensível é uma categoria específica que inclui, entre outros, dados sobre saúde e dados biométricos vinculados a uma pessoa natural. É importante observar que CPF e CIN são dados pessoais, mas não são automaticamente classificados como dados pessoais sensíveis pela definição legal.

O titular é a pessoa natural a quem os dados se referem; nesse cenário, normalmente é o aluno. O controlador é quem toma as decisões referentes ao tratamento dos dados, papel que pode ser exercido pela academia. O operador trata os dados em nome do controlador, como pode ocorrer com uma empresa fornecedora do sistema. A definição exata depende das atividades efetivamente realizadas por cada parte.

A lei apresenta princípios que orientam o tratamento. A finalidade exige objetivos legítimos, específicos e informados; a adequação requer compatibilidade entre o uso e a finalidade comunicada; a necessidade limita os dados ao mínimo necessário; a transparência exige informações claras; e a segurança e a prevenção orientam a adoção de medidas para reduzir riscos. A academia deve documentar por que cada informação é coletada, quem pode acessá-la e por quanto tempo precisa mantê-la.

O consentimento é uma das bases legais possíveis, mas não é a única. A base legal deve ser avaliada para cada finalidade. Por exemplo, determinados dados podem ser necessários para executar o contrato de matrícula ou cumprir uma obrigação legal. Para dados sensíveis, devem ser observadas as hipóteses específicas do artigo 11 da LGPD. Portanto, não se deve afirmar que todo tratamento exige consentimento, nem que o consentimento autoriza qualquer uso.

2.2 O ecossistema de uma academia de ginástica

Para planejar a proteção, os dados devem ser inventariados e agrupados conforme sua natureza e finalidade. A lista abaixo é uma proposta de mapeamento inicial e deve ser validada pela academia de acordo com as funções que realmente utiliza.

Dados cadastrais e de contato: nome, data de nascimento quando necessária, telefone, e-mail e endereço.

Dados contratuais e administrativos: plano contratado, data de matrícula, frequência, situação do vínculo e registros de atendimento.

Dados financeiros: valores de mensalidade, pagamentos, cobranças e histórico de transações. Dados completos de cartão devem ser evitados no sistema quando um prestador de pagamento seguro puder processá-los.

Dados de acesso: horários de entrada e saída e, se utilizada, biometria facial ou digital. A biometria vinculada ao aluno é dado pessoal sensível.

Dados de avaliação física e saúde: medidas corporais, limitações, lesões informadas, anamnese e recomendações relacionadas ao treino. Informações que revelem saúde são dados pessoais sensíveis.

Dados de comunicação e marketing: preferências de contato, registros de autorização quando aplicável, mensagens enviadas e solicitações de descadastro.

O inventário deve registrar a finalidade, a base legal avaliada, as pessoas com acesso, os sistemas envolvidos, o prazo de retenção e os destinatários externos. A academia

deve evitar coletar informações apenas por conveniência e não deve reutilizar os dados para uma finalidade incompatível com aquela informada ao titular.

2.3 Segurança da informação no desenvolvimento de software

Privacy by Design, ou privacidade desde a concepção, significa considerar a proteção de dados durante o planejamento, a construção, os testes e a manutenção do sistema, em vez de tentar corrigir todos os problemas somente depois de sua implantação. Isso inclui coletar apenas o necessário, definir permissões desde o início, proteger ambientes de teste e não utilizar dados reais de alunos em testes sem justificativa e salvaguardas adequadas.

A confidencialidade assegura que os dados sejam acessados somente por pessoas autorizadas. A integridade busca evitar alterações indevidas e permitir identificar mudanças relevantes. A disponibilidade procura garantir que usuários autorizados acessem o sistema quando necessário. No software proposto, esses objetivos podem ser apoiados por perfis de acesso, autenticação segura, validação das operações, registros de auditoria, cópias de segurança e testes de recuperação.

A segurança não depende apenas da tecnologia. Também são necessárias regras internas, treinamento dos funcionários, revisão periódica de permissões, atualização dos componentes, gestão de fornecedores e um procedimento de resposta a incidentes. A LGPD prevê a adoção de medidas técnicas e administrativas adequadas desde a concepção do serviço.

3. METODOLOGIA

Este trabalho caracteriza-se como pesquisa aplicada, de abordagem qualitativa e objetivo descritivo. É aplicada porque busca propor melhorias para uma situação prática; qualitativa porque analisa requisitos legais, processos e riscos sem depender de tratamento estatístico; e descritiva porque identifica dados, módulos e medidas de proteção pertinentes ao contexto de uma academia.

O procedimento adotado é a pesquisa documental, baseada na Lei nº 13.709/2018 e em materiais orientativos publicados pela Autoridade Nacional de Proteção de Dados (ANPD). A partir dessas fontes, são relacionados os principais processos de um software de academia com requisitos de privacidade e segurança. Como não foram fornecidos código-fonte, documentação técnica ou acesso a um sistema real, as

medidas descritas a seguir são propostas de adequação, não uma confirmação de que já estejam implementadas.

4. DESENVOLVIMENTO: DIAGNÓSTICO E ADEQUAÇÃO DO SOFTWARE

A adequação deve começar pelo levantamento dos dados efetivamente tratados e pela avaliação dos riscos de cada módulo. A tabela apresenta propostas para um sistema de gestão de academias. As medidas devem ser confirmadas e priorizadas pela equipe responsável antes da implantação.

Módulo do software	O que coleta/trata	Adaptação proposta para a LGPD
Controle de acesso	Registros de entrada e saída; eventualmente biometria facial ou digital.	Avaliar a necessidade da biometria e a base legal aplicável; informar claramente os alunos; oferecer alternativa razoável quando possível; restringir o acesso aos registros e proteger os dados biométricos.
Avaliação física	Medidas, anamnese, restrições e informações relacionadas à saúde.	Tratar dados sensíveis com proteção reforçada; limitar o acesso aos profissionais que realmente precisam; aplicar criptografia, registros de acesso e prazos de retenção definidos.
Gestão de treinos	Fichas de exercícios, objetivos e rotinas individuais.	Exigir autenticação; garantir que cada aluno visualize apenas seus próprios dados; restringir a exportação e impressão; registrar alterações relevantes.
Cadastro e matrícula	Identificação, contato, plano e informações contratuais.	Coletar somente o necessário; explicar finalidades e bases legais; permitir correção dos dados; aplicar permissões conforme a função do usuário.
Financeiro	Mensalidades, cobranças, pagamentos e histórico financeiro.	Limitar o acesso ao setor autorizado; evitar armazenar dados completos de cartão sem necessidade; proteger integrações com provedores de pagamento e manter registros de operação.

Marketing e CRM	E-mails, mensagens, preferências e campanhas promocionais.	Separar comunicações promocionais de avisos necessários ao serviço; registrar a base legal adequada; oferecer descadastro simples quando aplicável; não compartilhar listas sem fundamento legal.
Administração e relatórios	Relatórios, exportações e indicadores da academia.	Restringir exportações; mascarar ou agregar dados sempre que possível; registrar quem gerou ou baixou relatórios; evitar expor informações pessoais em telas compartilhadas.

4.1 Painel do titular (direitos do aluno)

O sistema deve oferecer um canal acessível para que o aluno solicite informações sobre o tratamento de seus dados. A interface pode incluir uma área autenticada ou um formulário de solicitação, com confirmação de identidade proporcional ao risco e acompanhamento do pedido. A academia deve estabelecer um processo para receber, analisar e responder às solicitações dentro dos prazos legais aplicáveis.

Entre as funcionalidades propostas estão:

- Consulta das informações pessoais mantidas no cadastro e explicação das finalidades do tratamento.
- Solicitação de correção de dados incompletos, inexatos ou desatualizados.
- Canal para solicitar informações sobre compartilhamento e tratamento dos dados.
- Registro e gestão da revogação do consentimento, quando o tratamento se basear nele.
- Solicitação de eliminação, anonimização ou bloqueio nos casos previstos em lei, respeitando situações em que a conservação seja necessária ou legalmente exigida.

A exclusão não deve ser apresentada como automática ou irrestrita em todos os casos. Cada solicitação precisa ser analisada conforme a base legal, a finalidade e as obrigações de conservação aplicáveis. O sistema deve registrar o pedido, as providências tomadas e a justificativa quando não for possível atender integralmente.

4.2 Segurança técnica do sistema

A segurança técnica deve combinar proteção dos dados armazenados, proteção durante a transmissão, controle de acesso, auditoria, backup e resposta a incidentes. As seguintes medidas são propostas para o sistema:

Criptografia em trânsito: utilizar HTTPS com TLS atualizado nas comunicações entre navegador, aplicação e serviços integrados.

Criptografia em repouso: proteger bancos de dados, discos e cópias de segurança com criptografia robusta, como AES-256, quando compatível com a infraestrutura. As chaves devem ser guardadas separadamente dos dados e ter acesso restrito.

Senhas: armazenar senhas usando algoritmo específico de hash para senhas, como Argon2id, com parâmetros seguros e salt individual. Não armazenar senhas em texto puro nem utilizar criptografia reversível para esse fim.

Controle de acesso: implementar contas individuais, permissões por função, princípio do menor privilégio, autenticação multifator para contas administrativas quando possível e remoção rápida de acessos de funcionários desligados.

Logs de auditoria: registrar eventos relevantes, como autenticações, tentativas negadas, consulta ou exportação de dados sensíveis e alterações administrativas. Cada registro deve incluir usuário, data e hora, ação e resultado, evitando guardar senhas, tokens ou conteúdo excessivo. O acesso aos logs deve ser restrito e as alterações devem ser protegidas.

Ferramentas de auditoria: utilizar o mecanismo de logs da aplicação e do banco de dados, centralizando-os em ferramenta de monitoramento quando viável. A ferramenta escolhida deve ser documentada e configurada para proteger os registros contra alteração e acesso indevido.

Backup e recuperação: realizar cópias de segurança periódicas, criptografá-las, manter cópias separadas do ambiente principal e testar regularmente a restauração.

Descarte seguro: definir prazos de retenção conforme a finalidade e as obrigações legais; eliminar ou anonimizar dados quando cabível; incluir cópias e exportações no processo de descarte.

Atualizações e incidentes: manter dependências atualizadas, testar vulnerabilidades, documentar um plano de resposta a incidentes e avaliar a necessidade de comunicação à ANPD e aos titulares em caso de incidente com risco ou dano relevante.

As escolhas de algoritmos e ferramentas devem ser validadas por profissional responsável pela segurança e pela infraestrutura. A criptografia, isoladamente, não garante conformidade: também são necessários processos, permissões, monitoramento, treinamento e revisão periódica dos riscos.

5. CONSIDERAÇÕES FINAIS

O objetivo deste trabalho foi analisar e propor requisitos técnicos, jurídicos e operacionais para adequar um software de gerenciamento de academias à LGPD. A análise identificou que o sistema pode tratar dados cadastrais, financeiros, registros de acesso e informações sensíveis relacionadas à saúde ou à biometria, exigindo medidas de proteção proporcionais à natureza dos dados e aos riscos.

As propostas incluem inventário de dados, definição de finalidade e base legal, controle de acesso por função, proteção das fichas de treino, cuidado especial com biometria e informações de saúde, atendimento aos direitos dos titulares, criptografia, logs de auditoria, backups e descarte seguro. Também se destacou a importância de planejar a privacidade desde a concepção e manter procedimentos de resposta a incidentes.

Conclui-se que a adequação à LGPD deve ser tratada como um processo contínuo de gestão e melhoria, e não como uma alteração isolada no software. A implementação das medidas propostas pode reduzir riscos, melhorar a organização interna e fortalecer a confiança dos alunos. Entretanto, como o trabalho não avaliou um sistema real, não é possível afirmar que os controles já estejam implementados ou que a academia esteja plenamente em conformidade. Essa conclusão depende de validação técnica, análise jurídica e acompanhamento das práticas efetivamente adotadas.

REFERÊNCIAS

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709compilado.htm. Acesso em: 23 out. 2026.

BRASIL. Autoridade Nacional de Proteção de Dados. Guia orientativo sobre segurança da informação para agentes de tratamento de pequeno porte. Brasília, DF: ANPD, 2021. Disponível em: https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia_seguranca_da_informacao_para_atpps___defeso_eleitoral.pdf. Acesso em: 23 out. 2026.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). Materiais educativos e publicações. Brasília, DF: ANPD. Disponível em: https://www.gov.br/anpd/pt-br. Acesso em: 23 out. 2026.

OBSERVAÇÃO PARA O GRUPO — REMOVER ANTES DA ENTREGA

Este documento é uma versão inicial completa para revisão. Confirmem se os nomes na capa (Marcelo Cardoso Vendrame, Gustavo Willian, Matheus Soares Gomes e Richard de Oliveira Barra Júnio) correspondem exatamente aos integrantes do grupo de Projeto Integrador II e ajustem o conteúdo às orientações do professor e às características do sistema que o grupo está desenvolvendo. As medidas técnicas são propostas, não funcionalidades comprovadamente implementadas. Revisem a formatação e as referências antes do envio.